Lab 5: Static Code Analysis

Mudit Chaturvedi | PES1UG24CS279 | Section 5E Software Engineering | 27 October 2026

Code checked

Repository: https://github.com/InterstellarMC/SE_MyProject_MicroLending_PES1UG24CS279

The scan covers all five Python files in `5-Github_Copilot_Generated_Code`: `credit_risk_assessor.py`, `amortization_schedule.py`, `escrow_marketplace.py`, `default_monitor.py` and `main.py`. These implement the borrower assessment, repayment schedule, loan funding and overdue-warning demo. The repository's eight existing tests were also run. The test file itself is outside the static-analysis scope.

The handout does not name an assigned repository. This report uses the Python implementation in the existing individual Software Engineering coursework repo. The exact original commit is recorded in `baseline.json`.

Before and after

Check	Before	After
Pylint 3.3.9	8.17/10	9.61/10
Bandit 1.8.6	0 findings	0 findings
Flake8 7.3.0	60 findings	0 findings
Existing pytest cases	8 passed	8 passed
Demo	Completed	Completed; output matches the original

No checker limits were relaxed and no warnings were suppressed. Pylint still returns exit code 8 because it has refactoring suggestions; the score is above the required 9.5. Bandit and Flake8 both return zero. The empty `after/flake8_report.txt` is the normal output of a clean run.

Issues and fixes

Line numbers below refer to the original files in the baseline commit. Pylint's W, C and R categories mean warning, convention and refactor; they are not Bandit's security severity levels.

Issue / tool	Original location	What was wrong	Change
Unused import: W0611 / F401	default_monitor.py:12	List was imported but never used.	Removed the import.
Missing class docstrings: C0115	credit_risk_assessor.py:14,22,31; amortization_schedule.py:15,27; default_monitor.py:15,23; escrow_marketplace.py:15,24,31	The data classes and enums did not explain what they represented.	Added short descriptions of their purpose.
Missing method docstrings: C0116	credit_risk_assessor.py:51; amortization_schedule.py:44,54; default_monitor.py:44; escrow_marketplace.py:54,60,63,126; main.py:16	The public methods had no docstrings.	Added a short explanation of each method's behavior.
Unnecessary parentheses: C0325	credit_risk_assessor.py:59	The comparison after not had an extra pair of parentheses.	Used not 0.0 <= ratio <= 1.0, preserving the original check.
F-strings without placeholders: W1309 / F541	main.py:56,82,114,124,132	Five constant messages used an f prefix.	Converted them to ordinary strings.
Long lines: C0301 / E501	For example, main.py:69; escrow_marketplace.py:110; default_monitor.py:101	Long messages, calls and comments exceeded the line limits.	Wrapped calls and comments; split strings using implicit concatenation. Output text stays the same.
Too many local variables: R0914	main.py:16	One function mixed the complete demo with repayment and alert details.	Moved those two parts into _show_repayment and _show_default_alerts. The main function no longer has the local-variable warning.

There were no Bandit findings, so no security fix was needed. In particular, there were no medium or high severity findings to prioritize. The first commit records that result rather than claiming a security vulnerability was fixed.

Verification

The final demo output was compared byte for byte with the saved original output and matched. All eight existing tests passed after the changes. They cover borrower approval and rejection, invalid profile inputs, schedule reconciliation, funding limits, insufficient balance, overdue warnings and proportional payouts. This checks the covered behavior; it does not prove every requirement is implemented.

The remaining Pylint suggestions concern large data records, argument counts, local variables in two calculation methods, service classes with one public method, and the number of statements in main. They remain in the report. Changing the public interfaces just to remove those messages would make this cleanup larger than necessary.

Reflection

The handout mentions reflection questions but does not list any. The following short questions cover the lab's stated learning outcomes.

What did the three tools contribute? Flake8 gave a clear list of formatting problems and caught the unused import and unnecessary f-strings. Pylint also flagged missing documentation and the size of the demo function. Bandit checked for known insecure coding patterns and reported none in this code.

Which changes were most useful? Removing the unused import was a small cleanup. Adding short docstrings made the public methods easier to understand. Separating the repayment and alert examples also made main easier to follow without changing the loan calculations.

Why run the program and tests again? A clean static-analysis report cannot confirm that the calculations still work. The existing tests checked the main behaviors, while the demo output comparison checked that the displayed results had not changed.

What are the limits of these results? A high Pylint score and a clean Bandit scan do not establish production security. For example, the in-memory escrow changes do not demonstrate serializable database transactions. Encryption, concurrent funding and real payment handling would need separate work and testing.

Files and commits

`before/` and `after/` contain the original tool output and final tool output. They also include the demo and test results. `baseline.json` records the starting commit; `results.json` records the final commands and exit codes. `requirements.txt` pins the analysis tools, and `environment.txt` records the installed environment (Python 3.9.6). The scanned code and existing tests ran successfully in that environment; the original README recommends Python 3.10 or newer for the project.

Three commits separate the work:

1. Record Bandit review and original analysis reports. 2. Fix Pylint documentation and simplify the demo. 3. Fix Flake8 formatting and add the final lab results.

The first is a security review/evidence commit because Bandit had no issues to fix. The other two contain code fixes for the reported issues.